

24. August 2026 | Bundesamt für Cybersicherheit BACS



Halbjahresbericht 2026/I (Januar–Juni)

Cybersicherheit

Lage in der Schweiz und international



Schweizerische Eidgenossenschaft
Confédération suisse
Confederazione Svizzera
Confederaziun svizra

Eidgenössisches Departement für Verteidigung,
Bevölkerungsschutz und Sport VBS
Bundesamt für Cybersicherheit BACS

Management Summary

Das Bundesamt für Cybersicherheit (BACS) beschreibt in seinem Halbjahresbericht die relevanten Vorfälle und Entwicklungen im Zusammenhang mit Cyberbedrohungen in der Schweiz und auf internationaler Ebene. Im ersten Halbjahr 2026 gingen beim BACS 27'128 freiwillige Meldungen sowie 200 meldepflichtige Cybervorfälle ein, womit sich der Meldeeingang auf einem hohen Niveau stabilisiert hat. Weiterhin dominiert Betrug als lukratives Massengeschäft die Statistik, wobei sich insbesondere Varianten via Telefon wie das «Voice Phishing» als Methode etabliert haben. Indem Kleinanzeigenplattformen, Suchmaschinenplatzierungen oder auch Datenlecks als Kontaktpunkt für Cyberkriminelle dienen, holen diese ihre Opfer mit persönlichen, emotionalen und auch teilweise technisch sehr ausgefeilten Methoden ab. Angreifer nutzen nun Künstliche Intelligenz (KI) systematisch, um zugeschnittene, personalisierte Inhalte glaubwürdig an die Opfer zu bringen.

Cybervorfälle bei Schweizer Unternehmen

Während grosse Kampagnen zu «CEO-Betrug» gegen Schulen, Gemeinden und Kirchen ausblieben, verzeichnete das BACS mehr Meldungen von Microsoft-365-«Phishing», wobei Angreifer die Geschäfts-E-Mail-Konten der Opfer übernehmen, um sie für weiteres Phishing oder Betrugsaktivitäten zu nutzen. Besonders augenfällig waren Fälle, bei denen mithilfe von gezielter Mitarbeitermanipulation IT-Helpdesks oder Führungspersonen imitiert wurden, um Systeme zu kompromittieren oder direkt Finanztransaktionen in die Wege zu leiten. Der Vorwand eines ausstehenden Sicherheitsupdates wurde in der Berichtsperiode ebenfalls vermehrt als Aufhänger verwendet, um Schadsoftware zu verteilen. Zudem ermöglichte die Kompromittierung mehrerer, viel genutzter Open-Source-Projekte die grossflächige Verbreitung von Software zum Diebstahl von Zugangsdaten. Schliesslich stagnierte die Anzahl der gemeldeten und beobachteten Schweizer «Ransomware»-Fälle bei 79 für diese Berichtsperiode, jedoch zeigt sich eine steigende Diversifizierung und Fragmentierung der aktiven Ransomware-Familien.

Cyberresilienz in einem zunehmend politisierten internationalen Umfeld

In internationalen Konflikten und erweiterten politischen Interessensräumen hat sich Cybersabotage zu einer praktikablen, oft offen durchgeführten Aktivität für einzelne Staaten entwickelt. Bislang gab es zwar keine gezielten Cybersabotage gegen kritische Infrastrukturen in der Schweiz, doch kann sich das Risiko in Abhängigkeit zur geopolitischen Lage ändern. Aufgrund der Nähe der Schweiz zu anderen westlichen Wertegemeinschaften und aufgrund ihrer wirtschaftlichen und politischen Verflechtung müssen sich Schweizer Organisationen darauf vorbereiten, auch in einem zunehmend feindseligeren Cyberbedrohungsumfeld ihre Widerstandsfähigkeit zu behaupten. Dies wird mithilfe einer Fallstudie zu einem Vorfall in Polen illustriert.

Das «Dream Job Playbook»

Stellensuchende standen in dieser Berichtsperiode unterschiedlich im Fokus. Nebst grossflächigen Kampagnen im Kontext typischer Betrugsmaschen nahmen Angreifer Schweizer Privatpersonen und Unternehmen ins Visier, um mithilfe eines fingierten Bewerbungsprozesses Kryptogelder zu stehlen. Die Angreifer kontaktieren ihre Opfer als angebliche Headhunter auf LinkedIn und offerieren vermeintliche Traumjobs oder Investitionsvorhaben. Neben dem Einsatz fortgeschrittener Social-Engineering-Techniken wenden die Angreifer ausgeklügelte Angriffsmethoden an, um die Geräte zu kompromittieren, an sensible Zugangsdaten zu gelangen und Kryptogelder von den Opfern und ihren Arbeitgebern in Millionenhöhe zu stehlen.

Inhalt

1	Cyberbedrohungen in der Schweiz – ein Überblick	3
2	Strategische Störungen im Cyberraum: eine Bedrohung für die Schweiz?	10
2.1	Herausforderungen der Cyberresilienz in einem politisierten Umfeld	12
2.2	Fallstudie: Vorfall im Energiesektor in Polen im Dezember 2025	14
2.3	Lehren für die Cyber-Resilienz in der Schweiz	17
3	Krypto-Diebstahl: Wenn der Traumjob ruft	19
3.1	Das «Dream Job Playbook»	19
3.2	Informationsasymmetrie	22
3.3	Kollektive Selbstverteidigung	23

1 Cyberbedrohungen in der Schweiz – ein Überblick

Die Cyberbedrohungslage in der Schweiz definiert sich nicht nur aufgrund nationaler Ereignisse, sondern ist eng mit der internationalen sicherheitspolitischen Entwicklung verknüpft. Angreifer passen ihre Methoden entsprechend kontinuierlich an dieses sich wandelnde Umfeld an. Das BACS hat zwar in der Masse für diese Berichtsperiode weniger Meldungen zu Cyberangriffen erhalten, jedoch werden diese in der Schweiz generell gezielter, emotionaler und technisch raffinierter. Während die gemeldeten Cybervorfälle ein stabiles Bild für die Schweiz vermitteln, haben sich das sicherheitspolitische Umfeld und die Sicherheitslage erheblich verschlechtert. Aufgrund von geopolitischen Spannungen und der Machtpolitik einzelner Staaten ist es wichtiger denn je, politische Faktoren für die Einschätzung der Cyberbedrohungslage zu berücksichtigen und diese in die eigene Einschätzung der Cyberrisiken einzubeziehen (vgl. Kap. 2.1). Dabei verdeutlichte der Sabotagevorfall in Polen anschaulich, dass fundamentale Sicherheitsmassnahmen für einen wirksamen Schutz vor Cyberbedrohungen unabdingbar sind (vgl. Kap. 2.2). Cyberresilienz wird aber nicht nur mit technischen Massnahmen erreicht, sondern sie muss ganzheitlich ausgerichtet sein und immer auch den Faktor Mensch einbeziehen. Mitmenschen müssen auf potenzielle Bedrohungen im Zusammenhang mit psychologischer Manipulation, professionellem, betrügerischem Auftreten und KI-unterstützte Angriffe aufmerksam gemacht werden (vgl. Kap. 3).

Zur Darstellung der Cyberbedrohungslage stützt sich der vorliegende Bericht überwiegend auf die freiwilligen Meldungen aus der Bevölkerung und der Wirtschaft. Seit der Einführung der Meldepflicht am 1. April 2025 für Betreiberinnen von kritischen Infrastrukturen¹ ergänzen die meldepflichtigen Meldungen das Cyberlagebild, wovon insgesamt 200 Fälle im ersten Halbjahr 2026 bearbeitet worden sind. Diese verteilten sich auf verschiedene Sektoren, wobei der öffentliche Sektor (19.4 %) und die IT und Telekommunikation (18.6 %) weiterhin am häufigsten Cyberangriffe gemeldet haben (vgl. Abb. 1). Mit knapp 26 Prozent ist der unbefugte Zugriff (Hacking) auf Systeme noch immer die am meisten gemeldete Angriffsart. Hierbei handelt es sich grösstenteils um kompromittierte E-Mail-Konten infolge erfolgreicher Phishing-Angriffe, welche dann ihrerseits für weitere Phishing-Angriffe und Betrugsversuche verwendet werden. Weiter folgen Meldungen zum Diebstahl von Zugangsdaten (13.5 %), zum Angriff auf die Verfügbarkeit («DDoS»²) (12.7 %) sowie Meldungen zu Datenabflüssen (12.7 %). Disruptive Angriffsarten wie Verschlüsselungs- und Erpressungstaktiken (Ransomware) waren in rund acht Prozent der Fälle zu verzeichnen (vgl. Abb. 2).

Im ersten Halbjahr 2026 zeigte sich bei den freiwilligen Meldungen ein Rückgang auf insgesamt 27'128 Meldungen (vgl. Abb. 3), verglichen mit 35'727 gemeldeten Cybervorfällen im ersten Halbjahr 2025. Dabei sind die am häufigsten registrierten Phänomene Betrug (10'759), Phishing (8'877) und Spam (3'965). Der verringerte Meldeeingang widerspiegelt sich in mehreren Kategorien wie unter anderem bei «Werbung für Online-Anlagebetrug» (387, -89 %³), bei CEO-Betrug (258, -57 %³) oder auch bei «betrügerische Drohanrufe im Namen von Behörden» (3'817, -64 %³). Bei Letzterem dürfte besonders die Verschärfung der Verordnung über Fernmeldedienste (FDV)⁴ hinsichtlich des Call-Spoofing zur positiven Entwicklung beigetragen

¹ [Informationen zur Meldepflicht \(bacs.admin.ch\)](https://bacs.admin.ch)

² [Angriff auf die Verfügbarkeit \(DDoS\) \(bacs.admin.ch\)](https://bacs.admin.ch)

³ Als Referenzperiode dient das erste Halbjahr 2025.

⁴ [Massnahmen gegen Missbrauch Schweizer Telefonnummern in Kraft \(swissinfo.ch\)](https://www.swissinfo.ch)

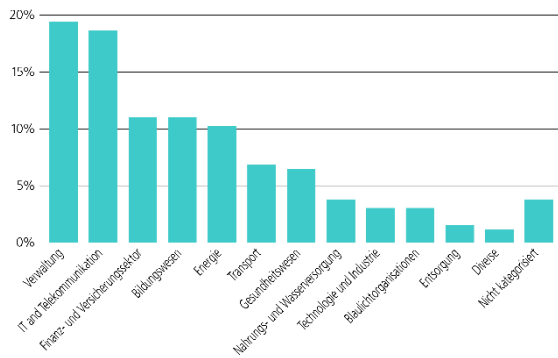


Abb. 3: Prozentuale Verteilung meldepflichtiger Cybervorfälle nach Sektoren, gemeldet an das BACS im ersten Halbjahr 2026

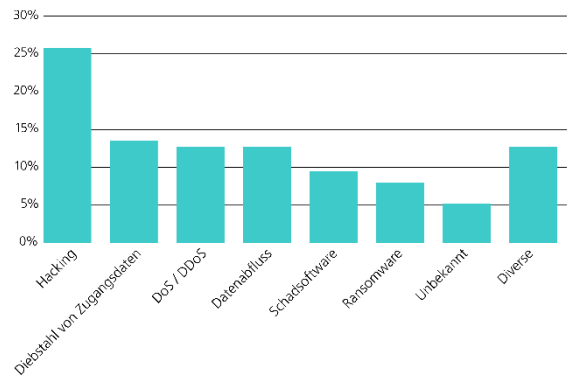


Abb. 2: Prozentuale Verteilung meldepflichtiger Cybervorfälle nach Angriffsart, gemeldet an das BACS im ersten Halbjahr 2026

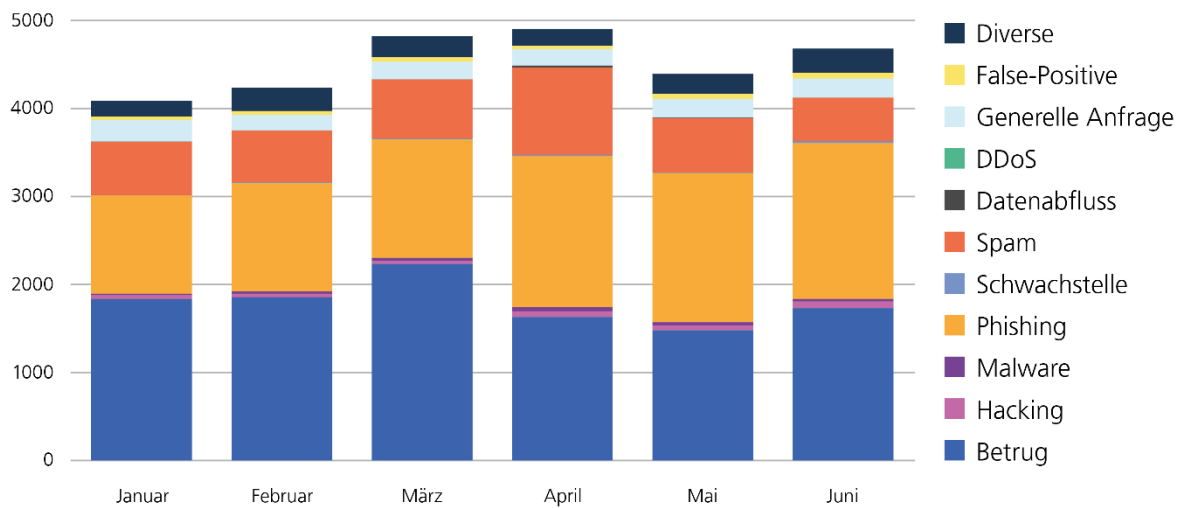


Abb. 1: Freiwillige Meldungen an das BACS im ersten Halbjahr 2026 nach Kategorien, vgl. [Aktuelle Zahlen \(bacs.admin.ch\)](https://bacs.admin.ch/aktuelle-zahlen)

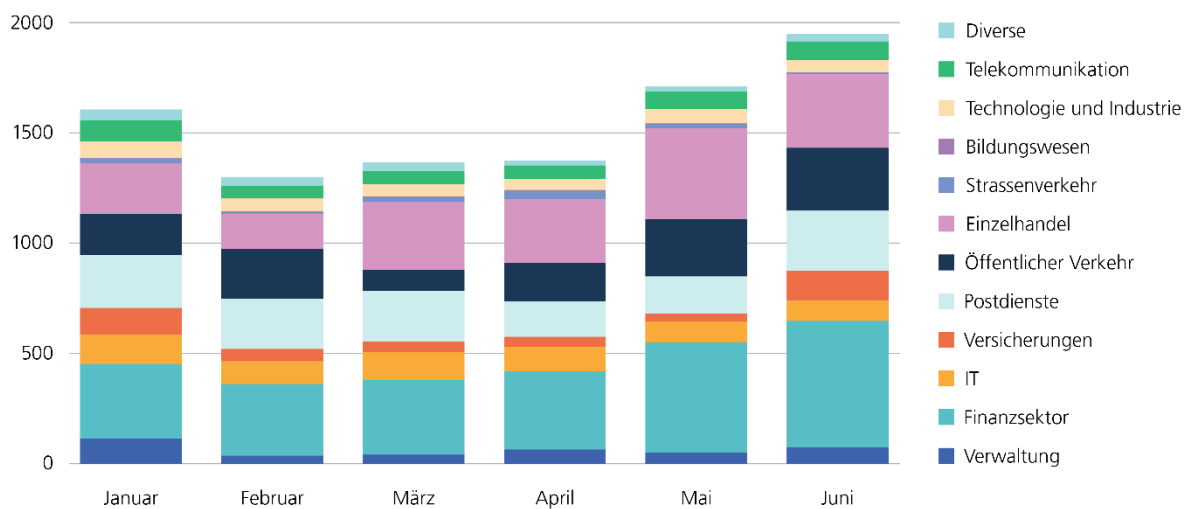


Abb. 4: Anzahl der durch das BACS überprüften und bestätigten Phishing-URLs nach Sektorenzugehörigkeit missbrauchter Marken im ersten Halbjahr 2026

haben, da diese Massnahmen wahrscheinlich bereits vor ihrem Inkrafttreten Wirkung zeigten.

Betrug

Betrug ist für Cyberkriminelle noch immer ein lukratives Massengeschäft, wobei ihr finanzieller Erfolg oder Misserfolg das Verhalten steuert. Diese Angriffsform zielt besonders auf die Schweizer Bevölkerung und Wirtschaft, denn rund 39 Prozent des Meldeeingangs waren Betrugsversuche. Generell lässt sich beobachten, dass sich KI bei der Erstellung betrügerischer Inhalte in Form von Text, Bildern, Videos und Stimme etabliert hat. Während Betrüger diese früher aus verschiedenen Quellen selbst beschaffen mussten, können sie nun innert Sekunden täuschend echte E-Mails, Textnachrichten und sogar komplette Websites mit KI erzeugen. So nutzten Kriminelle bei einem CEO-Betrugsfall in dieser Berichtsperiode ein imitiertes Stimmbild des Vorgesetzten, um Mitarbeitende zu betrügerischen Finanztransaktionen zu bewegen. Zwar sind solche Angriffe aufwändiger als der klassische CEO-Betrug, sie ermöglichen aber potenziell auch höhere Erfolgchancen. Ähnlich gelang es Betrügern beim «Romance Scam»⁵ mithilfe von durch KI zugeschnittenen Identitäten persönlicher und vertrauenswürdiger aufzutreten, wodurch sich die emotionale Bindung der Opfer verstärkte. Dabei kommen auch gefälschte Bilder, imitierte Stimmen bei Telefongesprächen und zunehmend auch mit «DeepFakes» unterstützte Videotelefonie zum Einsatz.

Auch entwickelten sich die von den Angreifern verwendeten Methoden hinsichtlich betrügerischer Jobangebote weiter. Während sich Fälle vergangener Berichtsperioden vor allem an Personen mit niedrigem Einkommen richteten, zielen aktuelle Varianten auch auf Führungskräfte ab.⁶ So locken angebliche Stellenvermittler beispielsweise mit attraktiven Positionen, verlangen jedoch kostenpflichtige Dienstleistungen wie etwa die Optimierung des Lebenslaufs als Vorleistung. Auch erhöhen Kriminelle ihre Glaubwürdigkeit gegenüber Stellensuchenden mit KI-generierten Websites von erfundenen oder imitierten Firmen. Schliesslich beobachtet das BACS seit geraumer Zeit ausgeklügelte «Social-Engineering»-Angriffe, bei denen gezielt Personen in IT- und Managementrollen betreffend eines angeblichen Traumangebots für Investitionen oder eine Traumstelle angeschrieben werden, um deren Systeme zu kompromittieren (vgl. Kap. 3). Dabei treten die Angreifer gezielt per E-Mail oder über digitale Netzwerke für berufliche Zwecke z. B. mit Software-Entwicklern in Kontakt, um diesen ein vermeintliches Stellenangebot schmackhaft zu machen. Beim darauffolgenden Gespräch wird das Opfer aufgefordert, eine technische Testaufgabe als Herausforderung zu lösen, über welche das Gerät des Opfers mit Schadsoftware («Malware») infiziert wird.⁷ Die Angreifer versuchen dabei, vom Opfer gehaltene Kryptowährungen zu stehlen und suchen dabei auch gezielt im Netzwerk des Arbeitgebers vom Opfer nach solchen Vermögenswerten.

Initialer Zugang

In Bezug auf den initialen Zugang («Initial Access») zur Kompromittierung von Systemen beobachtete das BACS keine Schweiz-spezifischen Vorgehen, sondern allgemeine globale Ent-

⁵ [Romance Scam \(bacs.admin.ch\)](https://bacs.admin.ch/Romance-Scam)

⁶ [Woche 23/2026: Stellensuchende im Visier – Phishing, Betrug und Schadsoftware im Bewerbungsprozess \(bacs.admin.ch\)](https://bacs.admin.ch/Woche-23/2026-Stellensuchende-im-Visier-Phishing-Betrug-und-Schadsoftware-im-Bewerbungsprozess)

⁷ [Woche 49/2025: Verlockende Jobs, versteckte Risiken – So tappen Stellensuchende in die Malware-Falle \(bacs.admin.ch\)](https://bacs.admin.ch/Woche-49/2025-Verlockende-Jobs-versteckte-Risiken-So-tappen-Stellensuchende-in-die-Malware-Falle)

wicklungen. Schadsoftware per E-Mail bleibt einer der Hauptvektoren, wobei gefälschte Rechnungen zu den häufigsten Vorwänden zählen.⁸ Weit verbreitet ist weiterhin «ClickFix»⁹, bei der das Opfer dazu gebracht wird, selbst einen schädlichen Befehl auszuführen. Im Berichtszeitraum identifizierte das BACS mindestens 191 Schweizer Websites mit einem WordPress-CMS, die Angreifer kompromittiert und auf denen sie schädlichen JavaScript-Code platziert hatten. Dieser veranlasst den Webbrowser des Besuchers der Website automatisch dazu, Schadcode nachzuladen.¹⁰ Dabei spielen vermehrt auch Blockchains eine Rolle, über welche zunehmend Schadcode gehostet und verteilt wird. Auch die Verwendung von «ClearFake», wobei das Opfer dazu animiert wird, ein vermeintliches Software-Update einzuspielen, ist weiterhin sehr beliebt. Ein Beispiel dazu ist eine Kampagne, bei welcher Angreifer Opfer für die angebliche Teilnahme an einem Meeting aufforderten, ein angebliches Update für die Zoom-App herunterzuladen und zu installieren.¹¹ Neben den eben genannten Methoden nutzen Angreifer auch mehrstufige Verfahren: Nachdem z. B. das geschäftliche E-Mail-Postfach eines Angestellten mit «E-Mail-Bombing» überzogen worden war, kontaktierten die Angreifer das Opfer anschliessend via Microsoft Teams und gaben sich als Mitarbeitende des IT-Helpdesk aus. Dabei überzeugten sie das Opfer, ihnen Fernzugriff zu gewähren, wodurch sie eine als Update getarnte Malware installieren konnten.¹²

Im Berichtszeitraum kam es ferner zu mehreren grossangelegten und folgenreichen Angriffen auf Software-Lieferketten mit globaler Relevanz. Die Kompromittierung mehrerer, viel genutzter Open-Source-Projekte ermöglichte die grossflächige Verbreitung von Software zum Diebstahl von Zugangsdaten, wobei auch Schweizer Organisationen betroffen waren.¹³ Parallel nutzten Angreifer weiterhin Schwachstellen in über das Internet erreichbaren Systemen aus, um an Zugangsdaten von z. B. VPN¹⁴-Produkten zu gelangen oder solche mit Malware zu kompromittieren.¹⁵ Solche Zugriffe wurden sogleich oftmals für den initialen Zugang verwendet, was zur Verschlüsselung durch Ransomware führte. Nichtsdestotrotz zeigen internationale Beobachtungen einen Wandel weg von technischer Komplexität hin zum Prinzip «log in, not break in»: Statt unautorisiert in ein System einzudringen, versuchen die Angreifer zunehmend, an legitime Zugangsdaten zu gelangen und sich so Systemzugriff zu verschaffen.¹⁶ Der Ende

⁸ [Woche 11/2026: Angreifer versuchen, Firmen und auch das BACS auszutricksen \(bacs.admin.ch\)](#) und auch Kap. 3

⁹ [Woche 8/2026: «ClickFix» – Wenn eine vermeintliche Fehlerbehebung oder Verifikation eine Malware installiert \(bacs.admin.ch\)](#)

¹⁰ Das BACS meldet kompromittierte Websites deren Betreiberinnen und Betreibern, damit diese sie bereinigen können.

¹¹ [Woche 26/2026: Wenn das Update zur Falle wird – Schadsoftware über gefälschte Zoom-Einladungen \(bacs.admin.ch\)](#)

¹² [When “Hi, This Is IT” Comes Through Microsoft Teams \(unit42.paloaltonetworks.com\)](#)

¹³ Siehe CSH – [Advisory] Aqua Security Trivy: Malicious Secret Exfiltration via Tag Compromise (csh.ch) und [The npm Threat Landscape: Attack Surface and Mitigations \(Updated June 2\) \(unit42.paloaltonetworks.com\)](#)

¹⁴ [BSI – Was ist ein virtuelles privates Netzwerk \(VPN\)? \(bsi.bund.de\)](#)

¹⁵ Siehe z. B. CSH – [Advisory] Adobe Commerce & Magento: Unauthenticated RCE via PolyShell (security-hub.ncsc.admin.ch) und [PayPal Felt Safe Until It Wasn't \(sourcedefense.com\)](#)

¹⁶ [Annual Threat Dynamics 2026 \(pwc.com\)](#)

des Halbjahres aufgetauchte Datensatz «FortiBleed» mit Konfigurationen und Zugangsdaten von Fortinet-Firewalls illustriert dies beispielhaft.¹⁷

Phishing

Im Zusammenhang mit Phishing gingen beim BACS über die Plattform antiphishing.ch¹⁸ in der Berichtsperiode 9'308 Meldungen zu einzigartige Phishing-URLs ein. Um an Zugangsdaten oder Kreditkarteninformationen zu gelangen, missbrauchten Angreifer bekannte Marken (vgl. Abb. 4). Am häufigsten betraf dies den Finanzsektor (26 %), den Einzelhandel und Dienstleistungssektor (22 %), sowie Postdienste (14 %). Während bis Ende 2025 noch klassisches Kreditkarten-Phishing den Meldeeingang dominierte, ist Phishing via Telefon unterdessen zur meist gemeldeten Phishing-Methode geworden. Nebst Varianten wie dem «Callback-Scam»¹⁹ bestimmt Voice Phishing in allen Varianten das Meldeaufkommen.²⁰ Dabei gab es auch doppeltes Phishing («Double Phishing»): Die Täterschaft deponierte zuerst eine gefälschte Paket-Abholaufforderung im Namen der Schweizerischen Post im Briefkasten, die via aufgedrucktem QR-Code sowohl die Kreditkartendaten als auch die Eingabe von Adresse und Telefonnummer verlangte. Danach riefen die Kriminellen die Opfer als angebliche Bankmitarbeitende an, um bei der Abwehr dieses Phishing-Angriffs zu unterstützen.²¹ In einigen Fällen kombinierten Betrüger Telefonanrufe mit physischen Besuchen. Auch TWINT-Phishing ist seit Mai 2026 deutlich angestiegen, zunächst über Angebote auf Kleinanzeigeplattformen wie Ricardo und Tutti²² und später im Zusammenhang mit gefälschten Hotelrückstellungen²³. Auch Unternehmen gerieten ins Visier: Einerseits kopierten die Angreifer sorgfältig den Webauftritt von Unternehmen, um Kreditkartendaten der Kunden bei integrierten Webshops zu stehlen. Andererseits stellt die Kompromittierung von Microsoft-365-Konten eine wachsende Bedrohung für Schweizer Organisationen dar. Mitarbeitende erhielten dabei E-Mails mit schädlichen Anhängen oder Links zu angeblichen SharePoint-Dokumenten. Hierbei hebelten die Kriminellen teilweise bewährte Sicherheitsmassnahmen wie Multi-Faktor-Authentisierung (MFA) durch abgefangene Sitzungstokens, «Device-Code-Phishing»²⁴ oder «Reverse Proxies»²⁵ aus. Anschliessend nutzten die Angreifer die Zugriffe für die Verteilung von Malware, Chain-Phishing²⁶ und Betrug mit Schadenssummen in Millionenhöhe.

¹⁷ Das BACS hat bei diesem Vorfall in Zusammenarbeit mit der Schweizer Gemeinschaft von Cybersicherheitsverantwortlichen potenziell betroffene Schweizer Organisation identifiziert und konnte anschliessend mit ungefähr 150 Organisationen zur Unterstützung in Kontakt treten. Für mehr Information zum Vorfall siehe bspw. [FortiBleed: 86,644 Fortinet Firewalls Compromised \(socradar.io\)](https://socradar.io).

¹⁸ Das BACS erhält Meldungen zu Phishing nicht nur in Form von Vorfallsmeldungen, sondern auch über die Plattform antiphishing.ch, welche zusätzliche Quellen miteinspeist. Eine Phishing-URL gibt keinen Hinweis darüber, wie grossflächig eine Phishing-Webseite geteilt wurde. Eine einzigartige Phishing-URL kann für einen einzelnen Versuch stehen oder auch für das Versenden an einen grossen Empfängerkreis.

¹⁹ [Woche 50/2025: Rückruf mit finanziellen Folgen \(bacs.admin.ch\)](https://bacs.admin.ch)

²⁰ [Woche 15/2026: Falsche Bankmitarbeiter fordern Installation von Fernwartungssoftware \(bacs.admin.ch\)](https://bacs.admin.ch)

²¹ [Woche 24/2026: Phishing im Briefkasten – Gefälschter QR-Code auf Abholungseinladung \(bacs.admin.ch\)](https://bacs.admin.ch)

²² [Woche 13/2026: Phishing-Mails im Namen von Kleinanzeigenplattformen – Erstverkäufer im Visier \(bacs.admin.ch\)](https://bacs.admin.ch)

²³ [Woche 22/2026: Gezielte Phishing-Welle im Namen von Buchungsplattformen und Hotels \(bacs.admin.ch\)](https://bacs.admin.ch)

²⁴ [Device Code Phishing: OAuth Attacks Across SaaS \(appomni.com\)](https://appomni.com)

²⁵ [Proxy servers and tunneling \(developer.mozilla.org\)](https://developer.mozilla.org)

²⁶ Siehe z. B. [Woche 11/2025: Kettenreaktion bei Microsoft 365-Phishing \(bacs.admin.ch\)](https://bacs.admin.ch)

Ransomware und Datenerpressung

Cyberangriffe finden noch immer in beträchtlicher Zahl im Kontext von Datenerpressung und Ransomware statt, wobei diese fast ausschliesslich auf Organisationen abzielen und das Schadenspektrum in der Schweiz von keinem Schaden bis hin zum Konkurs abdeckt. Statistisch registrierte das BACS gleich viele Ransomware-Vorfälle (79) in dieser Berichtsperiode wie im zweiten Halbjahr 2025 (vgl. Abb. 5). Die tatsächliche Zahl dürfte aber höher liegen, da nicht alle Betroffenen Vorfälle dem BACS melden. Generell zeigt sich anhand der Zahlen, dass sich das Ransomware-Ökosystem in der Schweiz zunehmend fragmentiert. Obwohl «Akira» zwar die am meisten dokumentierte Ransomware-Gruppierung in der Schweiz bleibt, sinkt ihr relativer Anteil der verübten Ransomware-Angriffe von rund 35 Prozent im letzten Halbjahr auf 19 Prozent im ersten Halbjahr 2026. Zugleich stieg die Zahl der in der Schweiz aktiven Ransomware-Familien von 21 auf 29, was für eine zunehmende Diversifizierung spricht. Beispielhaft für die allgemein instabile Dynamik dieses Bedrohungsumfelds ist «The Gentlemen»: Die Gruppe trat Anfang 2026 erstmals in der Schweiz in Erscheinung, erlitt aber Anfang Mai selbst ein Datenleck von Interna.²⁷ Ein solches Leck kann Beteiligte («Affiliates») dazu verleiten, sich anderen Ransomware-Gruppen anzuschliessen, denn auch Strafverfolgungsbehörden profitieren von den offengelegten Daten.

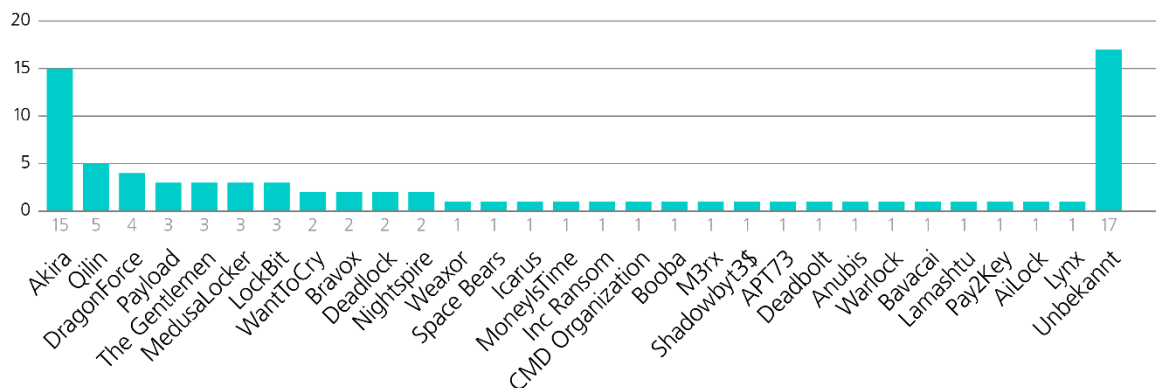


Abb. 5: Anzahl der dem BACS gemeldeten und beobachteten Erpressungsvorfälle im Kontext operierenden Ransomware-Gruppen im ersten Halbjahr 2026

Für den initialen Zugang nutzten Ransomware-Gruppen unter anderem Schwachstellen in über das Internet erreichbaren Systemen, insbesondere VPN und Firewalls. Gemäss internationalen Beobachtungen betrifft dies einen Drittel aller Ransomware-Vorfälle.²⁸ Mehrere Vorfälle zielten zudem auf Virtualisierungsinfrastrukturen, die zahlreiche Systeme bündeln. Durch deren Verschlüsselung können die Kriminellen grosse Teile der IT-Umgebung gezielt lahmlegen und den Druck zur Lösegeldzahlung erhöhen. In einigen Fällen verzichteten die Täter auf eine Verschlüsselung der Daten und setzten allein auf deren Exfiltration und das anschließende Drohen mit deren Veröffentlichung. Dieses Vorgehen ist bei kompromittierten Dienstleistern oder viel genutzten Plattformen zielführend, weil ein einziger erfolgreicher Zugang die Daten zahlreicher Organisationen preisgibt und sie erpressbar werden.²⁹ Letztlich sind solche

²⁷ [When the Ransomware Gang Gets Hacked: What the Gentlemen Leak Reveals About Modern Ransomware Risk \(blog.checkpoint.com\)](https://blog.checkpoint.com/2026/05/when-the-ransomware-gang-gets-hacked-what-the-gentlemen-leak-reveals-about-modern-ransomware-risk/)

²⁸ [Ransomware Tactics, Techniques, and Procedures in a Shifting Threat Landscape \(cloud.google.com\)](https://cloud.google.com/blog/topics/industry-trends/ransomware-tactics-techniques-and-procedures-in-a-shifting-threat-landscape)

²⁹ [How three techniques are behind ShinyHunters' 2026 campaigns \(pushsecurity.com\)](https://pushsecurity.com/blog/how-three-techniques-are-behind-shinyhunters-2026-campaigns)

Veröffentlichungen aber mit Vorsicht zu deuten: Mehrere angebliche Schweizer Opfer auf Daten-Leak-Seiten erwiesen sich auch in dieser Berichtsperiode als falsche Behauptungen.

DDoS-Angriffe

DDoS-Angriffe auf die Verfügbarkeit von Diensten und Systemen blieben in der Berichtsperiode in überschaubarem Rahmen für Schweizer Organisationen. Angriffe von Hacktivisten rund um Grossanlässe wie dem World Economic Forum (WEF) oder den Olympischen Winterspielen 2026 blieben praktisch aus. Dem BACS sind zudem versuchte Angriffe gegen die DNS-Infrastruktur und gegen einzelne E-Banking-Systeme bekannt, die jedoch zu keinen nennenswerten Ausfällen führten. Einzig ein 40 Minuten lang andauernder Internet-Netzausfall beim Telekomanbieter Salt führte zu grossflächig bemerkten Auswirkungen infolge eines DDoS-Angriffs.³⁰ Ein leicht anders gelagerter Vorfall ereignete sich auf der E-Mail-Infrastruktur des waadtländischen Parlaments. Politische Aktivisten schrieben Mitglieder des Parlamentes zu einem Geschäft an, was durch die hohe Anzahl eingehender, gleichlautender Nachrichten zu einer Überlastung des E-Mail-Dienstes (E-Mail Bombing) führte.³¹

Cyberspionage und -sabotage

Staatliche Cyberakteure («Advanced Persistent Threat», APT) betreiben weiterhin regelmässig Cyberspionage gegen Schweizer Ziele oder missbrauchen Schweizer IT-Infrastruktur, um aus der Schweiz Angriffe auf Drittstaaten durchzuführen.³² Dabei sind unzureichend geschützte Edge-Geräte, welche eine wichtige Schnittstelle ins Netzwerk der betroffenen Firma oder Behörde darstellen, besonders attraktiv, um als Einstiegspunkte zu dienen oder in Netzwerke von umfassenderen Angriffsinfrastrukturen integriert zu werden.³³

Zusätzlich zur Cyberspionage nutzen einzelne APTs auch Cybersabotage, um staatliche Interessen im Kontext von erhöhten geopolitischen Spannungen durchzusetzen. In Bezug auf die Schweiz sind dem BACS keine Cybersabotageangriffe gegen Schweizer Ziele bekannt. Neben dem Cybersabotage-Angriff auf die verteilte Energieerzeugung in Polen wurden auch im Umfeld weiterer internationaler Konflikte Sabotageversuche gegen cyberphysische Systeme registriert (vgl. Kap. 2). Die US-amerikanische Cybersicherheitsbehörde CISA warnte vor Angriffen gegen Steuerungsgeräte³⁴ durch iranische Akteure und vor Manipulationsversuchen gegen automatische Tankfüllstandmesssysteme³⁵. Ebenfalls im Zusammenhang mit geopolitischen Spannungen fand sich in der Karibik die zerstörerische Schadsoftware «LotusWiper»³⁶, welche sich gegen Systeme der venezolanischen Energieversorgung richtete. Eine interessante Entwicklung zeigte sich bei einem Angriff auf eine Wasserversorgungsinfrastruktur in Mexiko Anfang 2026, bei welchem KI die exponierten Systeme sowohl als mögliche Ziele vorschlug als auch den Angriff massgeblich unterstützte.³⁷ Das letzte Beispiel zeigt, dass mithilfe

³⁰ [Ce n'était pas un problème technique, mais une cyberattaque: l'agression contre Salt, symbole d'une Suisse vulnérable face à des hackers ciblant ses infrastructures critiques \(letemps.ch\)](#)

³¹ [Bund wiegelt ab wegen Spam-Attacke auf Waadtländer Parlament \(inside-it.ch\)](#)

³² Siehe für eine ausführliche Analyse zur Schweizer Sicherheitslage den Bericht [«Sicherheit Schweiz 2026»: Keine Entwarnung für die Schweiz \(vbs.admin.ch\)](#)

³³ Siehe [Halbjahresbericht 2025/2](#), Kap. 3.3

³⁴ [Iranian-Affiliated Cyber Actors Exploit Programmable Logic Controllers Across US Critical Infrastructure \(cisa.gov\)](#)

³⁵ [CISA and Partners Urge Hardening Automatic Tank Gauge Systems \(cisa.gov\)](#)

³⁶ [Highly destructive Lotus Wiper used in a targeted attack \(securelist.com\)](#)

³⁷ [AI-Assisted ICS Attack on a Water Utility \(dragos.com\)](#)

von KI künftig auch Akteure ohne spezifische Kenntnisse von industriellen Systemen fähig sein werden, ungenügend geschützte Systeme opportunistisch zu identifizieren und anschliessend zu manipulieren.



Melden Sie Cybervorfälle dem BACS über das Meldeformular unter report.ncsc.admin.ch oder wenden Sie sich direkt an die Spezialisten des BACS unter incidents@ncsc.ch. Verdächtige Phishing-E-Mails können Sie an reports@antiphishing.ch weiterleiten und verdächtige Webseiten direkt auf antiphishing.ch melden. Mit Ihrer Meldung helfen Sie dem BACS, die Schweizer Cyberbedrohungslage korrekt einzuschätzen, gezielt Warnungen herauszugeben und Massnahmen zu ergreifen, damit beispielsweise betrügerische Websites gesperrt werden können. Hilfestellung für die Bewältigung eines Cybervorfall finden Sie auf [der Website des BACS](#)³⁸.

2 Strategische Störungen im Cyberraum: eine Bedrohung für die Schweiz?



Kernpunkte

In internationalen Konflikten und erweiterten politischen Interessensräumen hat sich Cybersabotage zu einer praktikablen, oft offen durchgeführte Angriffsoption für einzelne Staaten entwickelt. Sie dient nicht nur dazu, gegnerische Infrastruktur zu beschädigen, sondern Cybersabotage ermöglicht es Angreifern auch, Schwachstellen in der Verteidigung des Gegners aufzuzeigen und der Öffentlichkeit eine Drohkulisse zu vermitteln. Bislang gab es zwar keine gezielte Cybersabotage gegen kritische Infrastrukturen in der Schweiz, doch dieses Risiko kann sich in Abhängigkeit zur geopolitischen Lage ändern.³⁹ Technische Möglichkeiten sowie die Nähe der Schweiz zu anderen westlichen Gesellschaften und ihre wirtschaftliche und politische Verflechtung mit diesen, könnten dennoch von einem Drittstaat ausgenutzt werden, um eigene Interessen durchzusetzen. Die Schweizer Infrastruktur könnte zu einem Stellvertreterziel werden, wenn Auswirkungen auf die vernetzte Infrastruktur anderer Staaten im Vordergrund stehen. Daher müssen sich Schweizer Organisationen darauf vorbereiten, auch in einem zunehmend feindseligeren Cyberbedrohungsumfeld ihre Widerstandsfähigkeit unter Beweis zu stellen.

³⁸ [Vorfall - Was nun? \(bacs.admin.ch\)](https://bacs.admin.ch)

³⁹ Zwar hat die Schweiz bisher noch keinen gezielten Cybersabotage-Angriff erlebt, doch kann sie von Kollateralschäden eines Cybersabotage-Angriffs in Drittstaaten betroffen sein. Zudem könnte ein staatlicher Akteur kritische Infrastrukturen der Schweiz ins Visier nehmen, um Staaten oder Allianzen zu schaden, die von diesen abhängig sind. Dieses Risiko ist besonders relevant im Zusammenhang mit der Führung hybrider Konflikte gegen NATO- und EU-Mitgliedstaaten. Weitere Informationen zur allgemeinen Bedrohungslage der Schweiz siehe [«Sicherheit Schweiz 2026»: Keine Entwarnung für die Schweiz \(vbs.admin.ch\)](#).

Kriege sind wieder ins Bewusstsein westlicher Gesellschaften, einschliesslich der Schweiz, gerückt. Zwar stellt eine direkte Beteiligung in einem Krieg für die Schweiz keine unmittelbare Bedrohung dar, jedoch befindet sich die internationale Ordnung aufgrund zunehmender Machtpolitik im Umbruch.⁴⁰ Dies bringt die Schweiz vor neue Herausforderungen, da die etablierte Sicherheitslandschaft laut dem Nachrichtendienst des Bundes (NDB) in Zukunft möglicherweise weniger Schutz bieten wird. Aufgrund dessen hat der Bundesrat Ende 2025 eine neue Sicherheitspolitische Strategie der Schweiz vorgeschlagen, die strategische Leitlinien, Ziele und Massnahmen vorgibt.⁴¹ Die Strategie identifiziert den Krieg zwischen Russland und der Ukraine als Wendepunkt für die Sicherheitspolitik. Denn er veranschaulicht die hybriden Merkmale der modernen Kriegführung zwischen Staaten, bei der Cybermittel zu einem integralen Bestandteil militärischer Operationen geworden sind. Wie die militärische Eskalation im Nahen Osten zeigt, beschränken sich solche Konflikte aber nicht auf eine einzelne Weltregion, sondern müssen global betrachtet werden.

Diese Entwicklungen haben Auswirkungen auf kritische Infrastrukturen hinsichtlich ihres Cybersicherheitsdispositivs und ihrer Prioritäten. Der Austausch des BACS mit internationalen Partnern zeigte, dass diejenigen, die starken geopolitischen Spannungen ausgesetzt sind, Vorbereitungsmaßnahmen für Worst-Case-Szenarien eingeleitet oder verstärkt haben, sogar im Hinblick auf bewaffnete Konflikte. In diesem Zusammenhang kam der norwegische Polizeisicherheitsdienst (PST) zur Einschätzung, dass Norwegen vor seiner schwerwiegendsten Sicherheitslage seit dem Zweiten Weltkrieg steht.⁴² Während auch in der Schweiz das Bewusstsein und die Besorgnis zunehmen, hat das BACS bei Schweizer Betreiberinnen kritischer Infrastrukturen noch kein vergleichbares Verständnis der Dringlichkeit wie in Norwegen oder anderen westlichen Ländern beobachtet.

Aus Verteidigungssicht hat die Cybersicherheit einen entscheidenden Vorteil gegenüber der traditionellen, kinetischen⁴³ Kriegführung: Der Cyberbereich ist auch im zivilen Leben eine vertraute Domäne. Insbesondere kritische Infrastrukturen waren schon immer mit einer Vielzahl von Cyberbedrohungen konfrontiert, was zu etablierten Verteidigungsprozessen beitrug, die in der sich rasch entwickelnden Bedrohungslandschaft kontinuierlich getestet und verbessert werden konnten. Im Kontext hybrider Konfliktführung können sich Cyberangriffe jedoch in einer Art und Weise manifestieren, die in Friedenszeiten kaum vorstellbar gewesen wären. Die folgenden Abschnitte beleuchten wichtige exogene – nicht beeinflussbare, externe – Faktoren, die die Resilienz der eigenen Lieferkette beeinflussen können. In einem zweiten Schritt werden Herausforderungen der Cyberbedrohungslandschaft für die Schweiz bewertet, indem spezifische technische Aspekte anhand einer Fallstudie untersucht werden.

⁴⁰ «Sicherheit Schweiz 2025»: Globale Konfrontation hat direkte Auswirkungen auf die Schweiz (vbs.admin.ch), S. 8 im Bericht

⁴¹ [Die Sicherheitspolitische Strategie 2026 \(sepos.admin.ch\)](https://sepos.admin.ch)

⁴² [National Threat Assessment 2026 \(pst.no\)](https://pst.no)

⁴³ Konventionelle, kinetische Kriegführung bezeichnet die Verwendung klassischer Militäroperationen im Rahmen eines bewaffneten Konflikts, bei der reguläre Militäreinheiten mindestens zweier Staaten mit Einsatz schwerer Waffen aufeinandertreffen. Die verursachten Schäden umfassen eine physische Komponente insbesondere in den Domänen Land, Luft, See und Weltraum, die beispielsweise durch Projektil und Explosivstoff herbeigeführt wird.

2.1 Herausforderungen der Cyberresilienz in einem politisierten Umfeld

Die Herausforderungen für die Cyberresilienz nehmen unterschiedliche Formen an, wenn der Fokus von der Gewinnmaximierung auf die strategische Widerstandsfähigkeit verlagert wird. Um Bedrohungen im Zusammenhang mit exogenen Faktoren wie geopolitischen Interessen entgegenzuwirken, sind mehrschichtige Massnahmen erforderlich, die die Geschäftskontinuität nach Betriebsunterbruch sicherstellen. Eine Organisation muss sich bewusst sein, welche Teile ihrer Aktivitäten auf welche Infrastruktur und welche Dienste angewiesen sind, unabhängig davon, ob diese selbst oder von Dritten betrieben werden. Solche Abhängigkeiten können durch externe Störungen, Infrastrukturausfälle bei Dritten oder deren Entscheidungen sowie jeweilige Rechtsordnungen beeinträchtigt werden. Daher muss eine Organisation nicht nur ihre technischen Abhängigkeiten bewerten, sondern auch das politische Umfeld, in dem sie direkt und indirekt tätig ist.

In den letzten Monaten haben Länder an der Ostsee zahlreiche externe physische Unterbrüche erlebt. Unterwasserkommunikations- und Stromkabel wurden durch Schiffsanker durchtrennt, die über den Meeresboden schleiften.⁴⁴ Ob es sich dabei um Unfälle oder um vorsätzliche Sabotage handelte, die von einer verdeckten politischen Agenda getrieben war, ist bislang nicht geklärt. Dennoch bleiben die Auswirkungen auf diejenigen, die auf die Infrastruktur angewiesen sind, dieselben. Die Länder an beiden Enden der Tiefseekabel verloren die durch die Kommunikations- und Stromverbindungen bereitgestellte Kapazität, doch dies konnte durch andere, noch funktionsfähige Infrastruktur kompensiert werden.⁴⁵

Solche Vorfälle können nicht nur die eigene Infrastruktur beeinträchtigen, sondern auch Ausfälle bei anderen Diensten verursachen, die für den Betrieb zahlreicher Organisationen unverzichtbar sind. Am 20. Oktober 2025 kam es z. B. bei Amazon Web Services (AWS) in der Region US-EAST-1⁴⁶ zu einer erheblichen Störung, die über 15 Stunden andauerte. Diese wirkte sich auf mehrere auf AWS basierende Dienste aus, darunter Slack, Atlassian und Snapchat. Der Ausfall begann mit einer «DNS-Race-Condition»⁴⁷, die eine komplexe Kaskade von Infrastrukturausfällen über mehrere voneinander abhängigen Systeme hinweg auslöste. Dies verdeutlicht, wie ein einzelner technischer Fehler in einer zentralen kritischen Infrastruktur auf vernetzte Cloud-Dienste übergreifen und zu Ausfällen bei anderen darauf aufbauenden Infrastrukturen führen kann.⁴⁸

Nebst der technischen Komponente können Entscheidungen wichtiger Dienstleister den Erfolg nachfolgender Operationen stark beeinflussen, einschliesslich solcher mit militärischem Bezug. Seit 2022 werden Starlink-Terminals im Krieg Russlands gegen die Ukraine aufgrund der

⁴⁴ [How the Baltic Sea nations have tackled suspicious cable cuts \(atlanticcouncil.org\)](https://atlanticcouncil.org/en/how-the-baltic-sea-nations-have-tackled-suspicious-cable-cuts)

⁴⁵ [Baltic Sea Cable Sabotage 2024–2025: When Ships Became Weapons \(geocables.com\)](https://geocables.com/baltic-sea-cable-sabotage-2024-2025-when-ships-became-weapons/)

⁴⁶ US-EAST-1 ist eine AWS-Region und steht für einen geografisch abgegrenzten Cluster, der sich aus mehreren voneinander unabhängigen Rechenzentren zusammensetzt, die aber durch schnelle Netzwerke miteinander verbunden sind. Im Gegensatz dazu ist der Cluster US-EAST-1 physisch von den anderen Clustern isoliert. Da US-EAST-1 jedoch zentrale globale Dienste wie Authentifizierung und DNS beherbergt, auf die auch andere Regionen und externe Dienste angewiesen sind, kann ein Ausfall in dieser Region weltweite Auswirkungen haben.

⁴⁷ [Race Conditions: The Silent Threat in Concurrent Systems \(medium.com\)](https://medium.com/race-conditions-the-silent-threat-in-concurrent-systems)

⁴⁸ [AWS Outage Analysis: October 20, 2025 \(thousandeyes.com\)](https://thousandeyes.com/aws-outage-analysis-october-20-2025)

verschlechterten Netzwerkverfügbarkeit sowohl von Zivilisten als auch von der ukrainischen Regierung und dem Militär intensiv genutzt. Während ukrainische Beamte ihre Abhängigkeit von der Dienstleistung eingeräumt haben, konnten sie bisher keine tragfähige Alternative finden, die eine ähnliche oder bessere Abdeckung und Dienstqualität bietet. Dies könnte erklären, warum russische Soldaten Starlink-Terminals über Dritte in besetzte Gebiete geschmuggelt und sie unter persönlichen Benutzerkonten ausserhalb Russlands registriert haben. Nach zwei Jahren dieser mutmasslich weit verbreiteten Nutzung von Terminals hat SpaceX alle Verbindungen in der Ukraine gekappt, mit Ausnahme derjenigen, die auf einer vom Verteidigungsministerium in Kiew genehmigten Liste standen. Ukrainische Zivilisten wurden aufgefordert, sich unter Verwendung ihrer persönlichen Identifikationsnummern neu zu registrieren. Dadurch blieben viele russische Einheiten ohne Netzwerk, was ihre Operationen behinderte. Letztendlich stellte die Nutzung von Starlink eine übermässige Abhängigkeit von einem Dienstleister dar, der ausserhalb ihrer Kontrolle Entscheidungen trifft und für den es keinen leicht verfügbaren Ersatz gibt.⁴⁹

Selbst wenn Dienstleistungen technisch reibungslos funktionieren, besteht ein Restrisiko, dass sie aufgrund von Sanktionen oder anderen staatlichen Massnahmen rechtlich eingestellt werden müssen. Da Anbieter verpflichtet sind, sich an die Rechtsordnung ihres Domizillandes zu halten, ist die Ausnutzung solcher Abhängigkeiten für Staaten zu einem attraktiven Mittel der Interessensdurchsetzung geworden. Insbesondere im Kontext der Machtpolitik hat die Bereitschaft in den letzten Jahren zugenommen, technische und wirtschaftliche Abhängigkeiten für den eigenen Vorteil auszunutzen.⁵⁰ So erlebte beispielsweise Karim Khan, der Chefankläger des Internationalen Strafgerichtshofs (IStGH), verschiedene Zugriffsverluste aufgrund von einer gegen ihn ausgesprochenen US-Sanktion, nachdem der IStGH einen Haftbefehl gegen den israelischen Premierminister Benjamin Netanjahu erlassen hatte. Infolge dieser Sanktionen konnte Khan sein berufliches Microsoft-E-Mail-Konto nicht mehr nutzen. Auch seine Bankkonten wurden eingefroren, wodurch Dienstleister des IStGH befürchteten, dass sie ebenfalls von Sanktionen betroffen sein könnten.⁵¹

Zusätzlich zu Sanktionen und anderen Machtkämpfen können Organisationen durch das Konzept der digitalen und datenbezogenen Souveränität⁵² vor Herausforderungen gestellt werden. Diese bestehen insbesondere im Zusammenhang mit internationalen digitalen Lieferketten. Dazu gehört beispielsweise, dass Organisationen, die Dienstleistungen von Anbietern mit Rechenzentren in einer anderen Rechtsordnung nutzen, die Vertraulichkeit der Daten möglicherweise nicht gewährleisten können, wenn der rechtlich zuständige Staat vom Anbieter Datenzugriff verlangt. Da der Anbieter das innerstaatliche Recht des Landes befolgen muss, in dem sich das Rechenzentrum befindet, sind sich die Kunden dieses Risikos möglicherweise nicht bewusst. Tatsächlich räumte Microsoft im Jahr 2025 vor dem französischen Senat ein, dass

⁴⁹ [Russian Forces in Ukraine Scramble to Overcome Musk's Starlink Restrictions \(twz.com\)](https://www.twz.com/russian-forces-in-ukraine-scramble-to-overcome-musk-s-starlink-restrictions)

⁵⁰ [Die Sicherheitspolitische Strategie 2026 \(sepos.admin.ch\)](https://sepos.admin.ch/Die-Sicherheitspolitische-Strategie-2026)

⁵¹ [Trump's Sanktionen gegen den Ankläger des IStGH haben die Arbeit des Gerichtshofs zum Erliegen gebracht \(apnews.com\)](https://www.apnews.com/Trump-s-Sanktionen-gegen-den-Anklaeger-des-IStGH-haben-die-Arbeit-des-Gerichtshofs-zum-Erliegen-gebracht)

⁵² [Bundesrat verabschiedet Bericht zur Digitalen Souveränität der Schweiz \(admin.ch\)](https://www.admin.ch/bundesrat/verabschiedet/Bericht-zur-Digitalen-Souveraenitaet-der-Schweiz),
[Digitale Souveränität: Die digitale Zukunft der Schweiz gestalten \(Whitepaper\) \(swissdataalliance.ch\)](https://www.swissdataalliance.ch/Digitale-Souveraenitaet-Die-digitale-Zukunft-der-Schweiz-gestalten)

die Datenhoheit für die eigene Rechtsordnung der Kunden nicht garantiert werden kann.⁵³ Abhängig von den für eine Organisation geltenden regulatorischen Anforderungen sind weitere Massnahmen wie anbieterunabhängige Verschlüsselung erforderlich, um Daten und Systeme zu schützen. Der Bundesrat plant, dieses Problem mit der «Swiss Government Cloud»⁵⁴ und der Einrichtung von Datenräumen in strategisch wichtigen Bereichen anzugehen.⁵⁵

Zusammenfassend lässt sich sagen, dass Organisationen bei ihrer Risikobewertung technische und organisatorische, aber auch politische Faktoren berücksichtigen müssen, um die Geschäftskontinuität sicherzustellen. Damit auch exogene Faktoren bewältigt werden können, ist ein mehrschichtiges Massnahmenpaket entscheidend. Das BACS hat hierzu zwei Empfehlungen veröffentlicht: «Das Notfallkonzept als Schlüssel zur Cyberresilienz»⁵⁶ sowie «Cybersicherheit in der Lieferkette»⁵⁷. Diese unterstützen Organisationen beim Identifizieren kritischer Abhängigkeiten und beim Setzen angemessener Prioritäten, mit dem Ziel auch in Krisenzeiten den kritischen Betrieb und die Vertraulichkeit der Daten sicherzustellen.

2.2 Fallstudie: Vorfall im Energiesektor in Polen im Dezember 2025

Geopolitische Konflikte verändern die Cyberbedrohungslandschaft nicht nur für die direkt beteiligten Parteien. Staatlich kontrollierte Akteure, die sich in der Vergangenheit meist auf verdeckte, langfristige Informationsbeschaffung konzentriert haben, führen zunehmend destruktive Angriffe auf kritische Infrastrukturen von Ländern durch, die sie als Gegner betrachten. Diese Verschiebung ist seit Beginn des Krieges in der Ukraine und in jüngerer Zeit auch im Iran zu beobachten. Was vorher in erster Linie ein Spionageproblem war, gekennzeichnet durch langandauernde und auf Unauffälligkeit ausgelegte Eindringversuche, wird nun mit sichtbarer Sabotagekampagnen kombiniert. Eine Reihe von Vorfällen in Polen Ende Dezember 2025 verdeutlicht, dass diese Entwicklung nicht nur am Krieg beteiligte Länder betrifft. Eine öffentliche Zuordnung durch das polnische Computer Emergency Response Team (CERT) attribuiert die Angriffsinfrastruktur zu «Static Tundra», einem mutmasslich staatlichen Bedrohungsakteur (APT) aus Russland,⁵⁸ der zuvor mit Spionage im Energiesektor in Verbindung gebracht wurde. Damit stellt der Vorfall in Polen die erste öffentlich dokumentierte Sabotageoperation dar, an der diese Gruppe offenbar beteiligt war.⁵⁹ Ferner zeigt der Fall, dass Länder, die mit einer der an einem Konflikt beteiligten Parteien in Verbindung stehen oder als mit dieser verbunden wahrgenommen werden, ebenfalls zu Zielen von Cybersabotage werden können.

⁵³ [Microsoft-Manager räumt ein, dass das Unternehmen die Datenhoheit «nicht garantieren kann» \(theregister.com\)](#), [CE Commande publique: Bericht über die Woche vom 9. Juni 2025 \(senat.fr\)](#)

⁵⁴ [Swiss Government Cloud \(bit.admin.ch\)](#)

⁵⁵ [Bundesrat verabschiedet Bericht zur digitalen Souveränität der Schweiz \(news.admin.ch\)](#)

⁵⁶ [Das Notfallkonzept als Schlüssel zur Cyberresilienz \(bacs.admin.ch\)](#)

⁵⁷ [Cybersicherheit in der Lieferkette \(bacs.admin.ch\)](#)

⁵⁸ [Russian Government Cyber Actors Targeting Networking Devices, Critical Infrastructure \(fbi.gov\)](#), [Russian state-sponsored espionage group Static Tundra compromises unpatched end-of-life network devices \(blog.talosintelligence.com\)](#)

⁵⁹ [Energy Sector Incident Report – 29 December 2025 \(cert.pl\)](#)

Am 29. Dezember 2025 führte eine koordinierte Angriffswelle gleichzeitig die IT- und Betriebstechnologie (OT) mehrerer polnischer Anlagen zur Störung der Energie- und Wärmeversorgung. Die Ziele reichten von 30 Wind- und Photovoltaikparks über ein grosses Blockheizkraftwerk bis hin zu einem Fertigungsunternehmen. Die Angreifer nutzten zudem gestohlene Zugangsdaten, um in die Cloud-Dienste der Opfer einzudringen. Sie zielten in erster Linie auf die verteilten Steuerungssysteme ab, die zur Fernsteuerung der Infrastruktur dienen, und nicht auf die physischen Anlagen wie Turbinen oder Generatoren selbst.

Bei den Anlagen für erneuerbare Energien konzentrierten sich die Angreifer auf den Netzananschlusspunkt (GCP), der im Wesentlichen die digitale Leitstelle des Infrastrukturbetreibers betreffend Steuerung und Fernüberwachung darstellt. Die Angreifer konnten sich ins Netzwerk einloggen, weil grundlegende Sicherheitsvorkehrungen vernachlässigt worden waren: Abgesehen von der Ausnutzung bekannter, ungepatchter Schwachstellen waren die Fernzugriffspunkte ohne Multi-Faktor-Authentifizierung (MFA) direkt dem Internet ausgesetzt, und dieselben Passwörter wurden auf mehreren Geräten wiederverwendet. In mehreren Fällen waren auf den Geräten noch die werkseitigen Standardpasswörter des Herstellers eingestellt. Betroffen waren die Firewall, Server⁶⁰ und verschiedene OT-Geräte wie Steuerungen⁶¹, «remote terminal units (RTU)»⁶², intelligente elektronische Geräte (IED)⁶³ wie Schutz- und Steuerrelais sowie Bedienoberflächen (HMI)⁶⁴. Einige dieser Systeme gewährten den Angreifern sogar Systemadministratorenrechte, die eine uneingeschränkte Kontrolle über das kompromittierte System ermöglichten. Sobald sich die Angreifer Zugang verschafft hatten, deaktivierten sie die Systeme auf unterschiedliche Weise: Einerseits beschädigten sie die Firmware der Steuergeräte, sodass die Geräte in einer endlosen Neustartschleife gefangen waren. Andererseits löschten sie wichtige Betriebssystemdateien, weshalb die Geräte nicht mehr hochfahren konnten, und setzten andere Komponenten auf die Werkseinstellungen zurück, während sie deren Netzwerkkonfiguration änderten, wodurch diese unerreichbar wurden. Auf den Windows-basierten Steuerungscomputern setzten sie zusätzlich sogenannte Wiper-Schadsoftware ein. Im Gegensatz zu Ransomware, die Dateien primär für die Lösegelderpressung verschlüsselt, besteht das Hauptziel von Wiper-Malware darin, Daten dauerhaft zu zerstören.⁶⁵

Das zweite Ziel des Angriffs war ein Heizkraftwerk, das rund 500'000 Personen in Polen mit Wärme versorgt. Anders als bei den Anlagen für erneuerbare Energien erfolgte die Sabotage hier ausschliesslich über das Büro-IT-Netzwerk, ohne die OT-Systeme wie z. B. das industrielle Steuerungssystem (ICS)⁶⁶ zu berühren. Die Angreifer verschafften sich Zugang über die Perimeter-Firewall des Unternehmens⁶⁷, indem sie Konten ausnutzten, die wiederum nicht durch MFA geschützt waren. Als die Angreifer sich dann im Netzwerk befanden, liessen sie sich Zeit: Im Laufe von etwa einem Monat erkundeten sie die Systemlandschaft. Sie ermittelten

⁶⁰ z. B. serielle Geräteserver von Moxa NPort

⁶¹ [Statement about Cyberattack in Poland \(publisher.hitachienergy.com\)](https://publisher.hitachienergy.com)

⁶² z. B. Mikronika-RTUs über Secure Shell (SSH)

⁶³ z. B. Hitachi Relion Schutz- und Steuerrelais (IEDs)

⁶⁴ SYNDIS ist eine SCADA-Software-Suite des polnischen Unternehmens Mikronika, die auf standardmässigen Windows-basierten Arbeitsstationen als Mensch-Maschine-Schnittstellen (HMIs) läuft.

⁶⁵ [Energy Sector Incident Report – 29 December 2025 \(cert.pl\)](https://cert.pl)

⁶⁶ [Industrial control system \(ICS\) \(csrc.nist.gov\)](https://csrc.nist.gov)

⁶⁷ Als Perimeter-Firewall wurde ein FortiGate-Gerät verwendet.

dabei, welche Systeme die industriellen Steuerungen des Kraftwerks erreichen konnten,⁶⁸ und stahlen unbemerkt Anmeldedaten, die es ihnen ermöglichten, sich als legitime Benutzer auszugeben.⁶⁹ Am 29. Dezember verteilten sie schliesslich die «DynoWiper»-Malware auf den Arbeitsplätzen des Unternehmens, indem sie dieselben Verwaltungs-Tools nutzten, die IT-Administratoren normalerweise für das Ausrollen von Software verwenden.⁷⁰ In diesem Fall erkannte jedoch eine Sicherheitslösung zur Überwachung der Arbeitsplätze (Endpoint Detection and Response, EDR) die Schadsoftware und blockierte sie, bevor sie weitreichenden Schaden anrichten konnte.

Anschliessend versuchten die Angreifer erneut, mit einer leicht modifizierten Version ihrer Malware den Angriff weiterzuführen, sie blieben jedoch erneut erfolglos. Daraufhin wollten sie, die Server des Unternehmens auf andere Weise zu zerstören, unter anderem durch das direkte Überschreiben von Daten auf den Festplatten und das Manipulieren der Konfiguration des Speichersystems.⁷¹ Keiner dieser Versuche führte jedoch zum beabsichtigten grossflächigen Schaden beim zweiten Angriffsziel.

Der dritte Cyberangriff richtete sich gegen ein Produktionsunternehmen. Im Gegensatz zu den anderen betroffenen Organisationen scheint dieses Opfer rein zufällig, weil die Angreifer eine Möglichkeit erkannten, das Unternehmen anzugreifen. Der Einstiegspunkt war erneut die Perimeter-Firewall des Unternehmens. Diesmal mussten die Angreifer diese jedoch nicht selbst überwinden: Die Konfiguration des Geräts, einschliesslich der Passwörter, war bei einem früheren, nicht damit in Zusammenhang stehenden Sicherheitsvorfall gestohlen worden und deshalb in einem kriminellen Online-Forum frei verfügbar. Nach der Anmeldung sicherten sich die Angreifer den dauerhaften Zugriff, indem sie automatisierte Routinen auf der Firewall einrichteten, die regelmässig gültige Anmeldedaten abriefen und die Sicherheitseinstellungen der Benutzerkontos schwächten, beispielsweise durch die Deaktivierung der MFA. Die Ergebnisse dieser Skripte sendeten die Angreifer aus Bequemlichkeit an einen Slack-Kanal. Sobald sie über einen SSL-VPN-Tunnel⁷² in das Unternehmensnetzwerk eingedrungen waren, breiteten sie sich mithilfe von Penetrationstest-Tools wie «Impacket» auf weitere Systeme aus. Wie

⁶⁸ Während der Erkundung wurde das Tool «PsExec» verwendet, um weitere Tools auszuführen und Screenshots zu erstellen sowie laufende Prozesse, Netzwerkverbindungen, Routing-Tabellen, den ARP-Cache (Address Resolution Protocol) und Benutzerverzeichnisse aufzulisten. Auf dem Domänencontroller versuchte der Angreifer, über SMB (Server Message Block) auf die Dateisysteme anderer Rechner zuzugreifen, deren Namen das Wort «scada» enthielten.

⁶⁹ Einen Monat nach dem Zugriff auf den Domänencontroller versuchte er, den LSASS-Prozess (Local Security Authority Subsystem Service) zu dumpen, und erstellte mit der Software Rubeus ein Diamond-Ticket. Anschliessend dumpete er die gesamte Active-Directory-Datenbank über die Datei ntds.dit.

⁷⁰ Die Angreifer nutzten Gruppenrichtlinienobjekte (GPO), um die Schadsoftware zu verbreiten. GPOs sind eine Windows-Verwaltungsfunktion, die es IT-Administratoren ermöglicht, Konfigurationseinstellungen und Software zentral und gleichzeitig auf alle Computer in einem Netzwerk zu übertragen.

⁷¹ Tatsächlich versuchten sie zudem, Serverfestplatten zu zerstören, indem sie eine Linux-Distribution booteten und mit dem «dd-Befehl» Teile der Festplatten überschrieben. Als letzten Versuch versuchte der Angreifer, die RAID-Konfiguration (Redundant Array of Independent Disks) zu ändern, um denselben zerstörerischen Zweck zu erreichen.

⁷² Ein SSL-VPN-Tunnel ist eine verschlüsselte Verbindung, die es Benutzern ermöglicht, über das Internet sicher auf ein Unternehmensnetzwerk zuzugreifen. Im Gegensatz zu herkömmlichen VPN-Lösungen erfordert er auf Benutzerseite lediglich einen Standard-Webbrowser oder einen schlanken Client, was ihn zu einer weit verbreiteten Fernzugriffsmethode in Unternehmensumgebungen macht.

beim zweiten Opfer setzten sie eine Wiper-Malware («LazyWiper») auf zahlreichen Computern ein, wobei sie erneut von der IT-Abteilung vorinstallierte Software⁷³ nutzten.⁷⁴

In allen drei Fällen nutzten die Angreifer gestohlene Anmeldedaten für die laterale Bewegung innerhalb der Opfersysteme. Entscheidend war, dass sie diese Anmeldedaten auch verwendeten, um in die lokalen und Cloud-Dienste der Opfer wie Microsoft Exchange, Teams und SharePoint einzudringen. Dort suchten sie gezielt nach Dateien und E-Mails, die sich auf den technischen Betrieb und auf Systeme wie ICS, OT und SCADA (Supervisory Control and Data Acquisition) der angegriffenen Organisationen bezogen. Entgegen dem allgemeinen Trend zu einem stetig zunehmenden Einsatz von Künstlicher Intelligenz (KI) und Automatisierung im Cyberbereich erforderte diese Angriffskampagne einen erheblichen manuellen Aufwand der Angreifer, da die drei Operationen parallel durchgeführt wurden.

Bemerkenswert ist, dass es sich bei den betroffenen Systemen überwiegend um solche handelte, die physische Prozesse überwachen und koordinieren. Entsprechend waren keine Teile der Infrastruktur betroffen, die direkt physische Zerstörung verursachen könnten, z. B. an Turbinen oder Generatoren. Dies ist ein relevanter Aspekt, da der Angriff einen erheblichen Planungsaufwand erfordert haben muss. Dennoch scheint der Zeitpunkt eher auf eine opportunistische Demonstration der Fähigkeiten (Signalling) hinzudeuten, um sich gegenüber geopolitischen Gegnern als Bedrohung darzustellen, als das Ergebnis eines sorgfältig gewählten strategischen Zeitpunkts. Die Tatsache, dass die Angreifer in der Lage waren, solche grundlegenden Schwachstellen – wie z. B. Standard- und wiederverwendete Passwörter, fehlende MFA, mangelhafte Umsetzung empfohlener Sicherheitskonfigurationen und unzureichend segmentierte Netzwerke – bei einer scheinbar relativ zufälligen Auswahl von Zielen auszunutzen, stützt diese Interpretation. Die Täterschaft führte die Angriffe durch, als sich die Gelegenheit bot, anstatt zu einem späteren, sorgfältig gewählten Zeitpunkt, der den grössten strategischen Vorteil gebracht hätte. Somit wären grundlegende Cybersicherheitsmassnahmen der Schlüssel zur Verhinderung dieser Angriffe gewesen, und nicht hochentwickelten Verteidigungstechnologien. Zum Grundschutz gehören Massnahmen wie z. B. starke, einzigartige Passwörter, die konsequente Nutzung von MFA, Netzwerksegmentierung und zeitnahes Patching von Sicherheitslücken.

2.3 Lehren für die Cyber-Resilienz in der Schweiz

Zunehmende geopolitische Spannungen und Kriege wirken sich selbst ausserhalb von Konfliktgebieten störend auf den sicheren Betrieb kritischer Infrastrukturen aus, weshalb sich auch Lehren für Schweizer Organisationen ableiten lassen. Im Allgemeinen führen staatliche Bedrohungsakteure Cybersabotage durch, wenn sich ihnen eine Gelegenheit bietet, eine beabsichtigte Wirkung, einschliesslich politischer Signale, herbeizuführen, die den staatlichen Interessen dient. Wenn solche Angriffe technisch machbar werden, müssen sich Organisationen dessen bewusst sein, dass sie ins Visier geraten können, wenn Akteure ein Interesse ableiten. Dies bedeutet, dass insbesondere grundlegende Massnahmen zur Förderung einer soliden Cybersicherheit durchgesetzt werden sollten.

⁷³ Die Angreifer nutzten erneut GPOs, um den LazyWiper-PowerShell-Wiper von einer Netzwerkfreigabe aus auszuführen.

⁷⁴ [Energy Sector Incident Report – 29 December 2025 \(cert.pl\)](#), Kap. "Malware Analysis"

Bei solchen Angriffen ist die politische Signalwirkung von Cyberfähigkeiten gegenüber einem nationalen oder internationalen Publikum ein wichtiges Ziel. Ein damit verbundenes Ziel kann darin bestehen, in der Öffentlichkeit ein Klima der Angst, Unsicherheit und Bedrohung zu schüren. Ein Beispiel für diesen Mechanismus wird im Zusammenhang mit dem Krieg im Iran im März 2026 dargestellt. Mit dem Iran verbundene Angreifer behaupteten, alle zugänglichen Geräte des US-amerikanischen Medizintechnikherstellers Stryker durch einen Werk-Reset gelöscht zu haben.⁷⁵ Das Unternehmen war bei weitem nicht das strategisch relevanteste Ziel, aber es ermöglichte es den Angreifern, ihre Cyberfähigkeiten zu demonstrieren und der Öffentlichkeit eine Botschaft der Rache zu vermitteln.⁷⁶ Tatsächlich haben Angriffe, die mediale Aufmerksamkeit erregen, insbesondere in Demokratien, eine erhöhte nicht-physische Wirkung, da sie die öffentliche Meinung und damit das Mass an Unterstützung für das militärische Engagement des Landes beeinflussen können. Darüber hinaus betraf dieser Vorfall auch Schweizer Geschäftskunden von Stryker. Als direkte Folge konnten diese ihre nächste Bestellung benötigter Produkte nicht über die etablierten Kanäle abwickeln. Daher müssen auch Schweizer Organisationen politische Faktoren bei ihrer Risiko- und Bedrohungsanalyse für sich selbst und ihre Lieferketten berücksichtigen.

Zudem müssen sich Schweizer Organisationen ihrer Abhängigkeiten von Anbietern wesentlicher Dienstleistungen und Produkte bewusst sein, um künftige Herausforderungen bewältigen zu können. Wie der Angriff auf Anlagen der dezentralen Energieerzeugung in Polen gezeigt hat, kann die Strominfrastruktur zum Ziel zerstörerischer Cyberangriffe werden. Darüber hinaus entwickelt sich auch die Schweiz in eine Richtung, in der die Stromerzeugung aus erneuerbaren Energien für die gesamte Energieversorgung zunehmend an Bedeutung gewinnt. Auch bei Systemen der erneuerbaren Energien könnten in Schweizer Netzwerken unzureichend geschützte Netzwerkgeräte zu finden sein. Im Gegensatz aber zu Polen sind grosse Netzanschlusspunkte in der Schweiz grossmehrheitlich besser isoliert. Dies berücksichtigt jedoch nicht die grosse Anzahl kleinerer privater Einspeiser in das Stromnetz. Diese Systeme sind ständig mit dem Internet und der Cloud des Herstellers verbunden. Wie das Nationale Testzentrum für Cybersicherheit (NTC) in seiner Studie zu Energiemanagementsystemen für private Photovoltaikanlagen feststellt, entstehen dadurch neue Abhängigkeiten und eine breite Angriffsfläche für Cyberbedrohungen.⁷⁷

Um die Schweizer Systemlandschaft abzusichern und sie auf potenzielle künftige disruptive Angriffe vorzubereiten, müssen kohärente Ansätze wie die Cybersicherheits- und Resilienzmethode (CSRM) des BACS⁷⁸ breit angewendet werden. Dies stellt sicher, dass nicht nur einzelne kritische Systeme solchen Sabotageversuchen standhalten können, sondern dass die grundlegenden Dienstleistungen auch in einer zunehmend angespannteren Cyberbedrohungslage bereitgestellt werden können.

⁷⁵ [Iran-linked hackers claim responsibility for attack on US medical device maker Stryker \(reuters.com\)](https://www.reuters.com/technology/iran-linked-hackers-claim-responsibility-attack-us-medical-device-maker-stryker-2026-03-01/);
[Justice Department Disrupts Iranian Cyber Enabled Psychological Operations \(justice.gov\)](https://www.justice.gov/opa/pr/justice-department-disrupts-iranian-cyber-enabled-psychological-operations-2026-03-01)

⁷⁶ [CISA Urges Endpoint Management System Hardening After Cyberattack Against US Organization \(cisa.gov\)](https://www.cisa.gov/news-events/press-releases/stories/2026/03/01/cisa-urges-endpoint-management-system-hardening-after-cyberattack-against-us-organization)

⁷⁷ [The overlooked rooftop threat \(ntc.swiss\)](https://www.ntc.swiss/en/press-releases/2026/03/01/the-overlooked-rooftop-threat)

⁷⁸ [Cybersicherheits- und Resilienzmethode \(CSRM\) \(bacs.admin.ch\)](https://www.bacs.admin.ch/de/cybersicherheits-und-resilienzmethoden)

3 Krypto-Diebstahl: Wenn der Traumjob ruft



Kernpunkte

Cyberbedrohungsakteure nehmen Schweizer Privatpersonen und Unternehmen in den Fokus, um mithilfe eines fingierten Bewerbungsprozesses Kryptogelder zu stehlen. Ein erheblicher Teil der Schweizer Wirtschaft ist durch diese Kryptobetrugsmasche gefährdet, bei der vermeintliche Traumjobs angeboten werden. Die Angreifer kontaktieren ihre Opfer dabei als angeblichen Headhunter auf LinkedIn, wobei sie ihnen eine äusserst attraktive, aber erfundene Stellenausschreibung anbieten. Neben dem Einsatz fortgeschrittener Social-Engineering-Techniken wenden die Angreifer ausgeklügelte Angriffsmethoden an, um die Geräte der Opfer zu kompromittieren und so an sensible Daten und Zugangsschlüssel zu gelangen. In einem zweiten Schritt versuchen sie dann, sich über die kompromittierten Geräte der Opfer Zugang zu weiteren Systemen zu verschaffen, darunter auch jene der Arbeitgeber. Diese Angriffe ähneln Angriffsmustern internationaler Kampagnen, die andere Behörden zuvor Cyberbedrohungsakteuren zugeschrieben haben, die im Auftrag der Demokratischen Volksrepublik Korea (DVRK) operieren. Um Schweizer Unternehmen und Privatpersonen besser vor dieser Art von Cyberangriffen zu schützen, sind dedizierte kollektive Massnahmen erforderlich, die zu einer Sensibilisierung der Öffentlichkeit und einem besseren Informationsaustausch zwischen den betroffenen Organisationen und Personen führen.

3.1 Das «Dream Job Playbook»

Schweizer Privatpersonen und Unternehmen aus den Bereichen Krypto, Blockchain und Web3 wurden Opfer einer Reihe von Kryptowährungsdiebstählen, die alle einem sehr ähnlichen Muster folgten, nämlich dem «Dream Job»-Szenario. Tatsächlich handelt es sich bei den nachfolgend beschriebenen Szenarien keineswegs um Einzelfälle, da sie starke Ähnlichkeiten mit einer lang andauernden, globalen Cyberkampagne aufweisen, die ursprünglich als «Operation Dream Job»⁷⁹ und in ihrer neueren Variante, oft als «Contagious Interview»⁸⁰ bezeichnet, bekannt wurde. Diese Angriffsmuster wurde von anderen Behörden und Cybersicherheitsforschern im Kontext internationaler Kampagnen Cyberbedrohungsakteuren zugeschrieben, die mutmasslich im Auftrag der DPRK operieren.⁸¹ Bei diesen Angriffen ist Social Engineering das entscheidende Element für den Erfolg der Angreifer (vgl. Abb. 6). Die Angreifer beginnen in der Regel mit einer umfangreichen Vorbereitungsphase, bevor sie sich dem späteren Opfer

⁷⁹ siehe [Operation Dream Job \(attack.mitre.org\)](https://attack.mitre.org)

⁸⁰ Neuere Angriffe fallen meist unter die Kategorie «Contagious Interview» (siehe z. B. [«Contagious Interview: Malware delivered through fake developer job interviews» \(microsoft.com\)](https://www.microsoft.com/en-us/security/default.aspx?query=contagious+interview)). Während die Kampagne «Contagious Interview» erstmals im Jahr 2022 beobachtet wurde, reicht «Operation Dream Job» jedoch bis ins Jahr 2019 zurück. Im Gegensatz zu den heute vorherrschenden finanziell motivierten Angriffen richteten sich die frühen «Dream Job»-Angriffe auf Cyberspionage und zielten auf die Bereiche Verteidigung, Luft- und Raumfahrt, Regierung und andere Sektoren ab.

⁸¹ Siehe u. a. [North Korea Responsible for \\$1.5 Billion Bybit Hack \(fbi.gov\)](https://www.fbi.gov/newsroom/stories/press-releases/2022/03/22-nk-responsible-for-1.5-billion-bybit-hack), [Don't Fear the Repo: UNK DeadDrop Phishing Campaign Targets Developers to Steal Cryptocurrency \(proofpoint.com\)](https://www.proofpoint.com/en/newsroom/articles/2022/03/22-dont-fear-the-repo-unk-dead-drop-phishing-campaign-targets-developers-to-steal-cryptocurrency), [GitLab Threat Intelligence Team reveals North Korean tradecraft \(gitlab.com\)](https://www.gitlab.com/blog/2022/03/22/gitlab-threat-intelligence-team-reveals-north-korean-tradecraft), [DPRK Adopts EtherHiding: Nation-State Malware Hiding on Blockchains \(cloud.google.com\)](https://cloud.google.com/blog/topics/industry-trends/dprk-adopts-etherhiding-nation-state-malware-hiding-on-blockchains)

zuwenden. Zu diesem Zweck identifizieren sie zunächst Personen in Schlüsselpositionen innerhalb lukrativer Zielorganisationen, die vermutlich privilegierten Zugriff auf bestimmte Systeme und Gelder innerhalb ihres Unternehmens besitzen. Ein solches Beispiel wäre ein unabhängiger Software-Entwickler oder der Gründer einer Krypto-, Blockchain- oder Web3-Organisation. Sobald die Angreifer eine Person ausgewählt haben, wechseln sie in den Erkundungsmodus, indem sie sich ein detailliertes Bild von ihrem Ziel machen. Dazu gehören z. B. der bevorzugte Technologie-Stack⁸² des Opfers, persönliche Interessen, Investitionsabsichten, der Zugang zu Unternehmensmitteln und natürlich die Grösse der Krypto-Wallets.

Anschliessend gibt sich der Angreifer als gut vernetzter, gewandter Headhunter aus und kontaktiert die ausgewählte Person über LinkedIn mit einem Stellenangebot, das sie fast nicht ablehnen kann oder vielmehr nicht ablehnen will. Das Angebot ist einfach und überzeugend: Um ein grosszügiges sechsstelliges Gehalt zu verdienen, muss ein Software-Entwickler lediglich eine Testanwendung ausführen und Fehler beheben. Dazu soll das Opfer nur auf ein Software-Repository⁸³ zugreifen und seine technischen Fähigkeiten unter Beweis stellen. Der Kandidat ist sich jedoch nicht bewusst, dass sein System durch das Herunterladen des Codes aus dem umworbenen Software-Repository unbemerkt durch Malware kompromittiert wird.

In anderen Fällen werden Personen mit einem weniger technischen Hintergrund durch ähnlich verlockende Angebote massgeschneiderter Traumjobs geködert und auch bei ihnen geht ein glaubwürdiger Bewerbungsprozess voraus. Dank ihrer Vorrecherchen kennen die Angreifer die Wünsche ihrer Opfer genau. So geben sie sich beispielsweise als Risikokapitalgeber auf der Suche nach dem nächsten «Unicorn»-Unternehmen aus oder bieten selbst einem Back-office-Mitarbeiter eine gut bezahlte Stelle als Betriebsleiter an. Die angeblichen Personalvermittler vereinbaren einen Videointerview und senden dem Opfer einen Link. Das Gespräch beginnt meist angenehm, doch dann bricht scheinbar die Verbindung ab und der Kandidat glaubt, technische Probleme zu haben. Daraufhin schlägt der Interviewer überzeugend vor, einen schnellen Hotfix auszuführen, um die Videokonferenzlösung zu reparieren. Während die Angreifer oft legitime Videokonferenz-Software wie Microsoft Teams, Zoom oder Google Meet verwenden und die Opfer glauben machen, dass bei den Opfern ein technisches Problem vorliegt, erweist sich der Hotfix als bösartig und steht unter der Kontrolle des Angreifers. Wenn das Opfer den Hotfix ausführt, rufen diese gefälschten Updates entweder trojanisierte Software-Abhängigkeiten auf oder laden direkt eine Malware-Datei der zweiten Angriffsstufe namens «Ottercookie» oder «Beavertail» herunter⁸⁴. Dies ermöglicht es den Angreifern, die Zugangsdaten, Tokens oder Wallet-Schlüssel des Opfers zu erlangen, indem sie die Daten vom kompromittierten Gerät auf ihre Command-and-Control-Server (C2) exfiltrieren. Darüber hinaus versuchen sie, sich lateral im Unternehmensnetzwerk des Opfers zu bewegen, um weitere wichtige Daten zu stehlen. Bis das Opfer bemerkt, dass der Bewerbungsprozess von Anfang

⁸² [Software-Stack \(computerweekly.com\)](https://computerweekly.com)

⁸³ Ein Repository ist ein zentraler, strukturierter Speicherort, in dem digitale Inhalte wie z. B. Software-Code, Dokumente oder Daten abgelegt, verwaltet und bei Bedarf abgerufen werden können.

⁸⁴ «Ottercookie» und «Beavertail» sind verschleierte Schadsoftware-Payloads, die regelmässig mit den Cyberaktivitäten der DVRK in Verbindung gebracht werden. Ihre Entwickler passen diese Schadsoftware-Exemplare kontinuierlich an die Anforderungen neuer Kampagnen an. Sie werden ausschliesslich im Arbeitsspeicher ausgeführt und führen oft zum Einsatz einer massgeschneiderten Backdoor der DVRK namens «InvisibleFerret», die es den Angreifern ermöglicht, auf dem Gerät des Opfers eine dauerhafte Präsenz aufrechtzuerhalten. Bislang wurden keine Fälle gemeldet, in denen andere bekannte Bedrohungsakteure diese spezifischen Schadsoftware-Exemplare eingesetzt hätten.

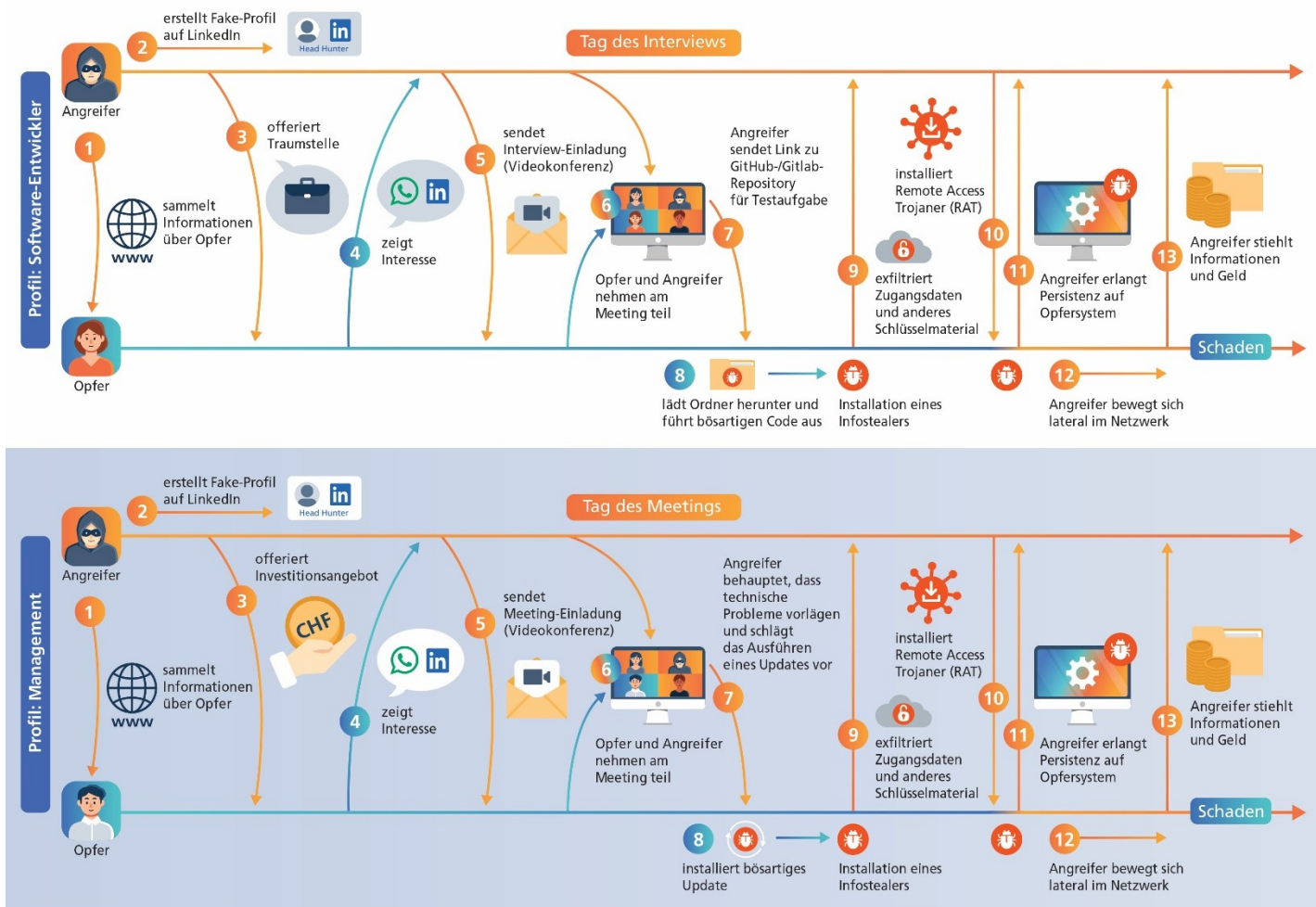


Abb. 6: Das «Dream Job Playbook» Schritt für Schritt in der Übersicht

bis Ende inszeniert war, sind die eigenen Krypto-Vermögenswerte und möglicherweise auch die Gelder des Arbeitgebers auf den verschlungenen Wegen der Geldwäscherei bereits abgezogen worden, um schliesslich auf die Konten des Angreifers überwiesen zu werden.

In der Schweiz haben Meldungen über solche betrügerische Traumjobangebote in den letzten fünf Jahren stetig zugenommen, womit sich das Meldeaufkommen bei mehr als 20 gesicherten Fällen befindet. Die Opfer sind oft mit der Kryptoindustrie verbunden, während ihre Positionen von Ingenieur- bis hin zu Führungsrollen reichen können. Das BACS wird wöchentlich von Opfern kontaktiert, die den betrügerischen Charakter der Kontaktaufnahme erkennen und die mit Trojanern versehenen Bewerbungsapplikationen melden oder denen es gelingt, Infektionen zu beseitigen, bevor es zu einem finanziellen Schaden kommt. Leider erhielt das BACS ebenso viele Meldungen von Opfern, die erst im Nachhinein bemerkten, was ihnen widerfahren ist. Diese Privaten und Unternehmen erlitten aufgrund der Kryptodiebstähle Schäden in Höhe von einigen Tausend bis hin zu rund 60 Millionen Schweizer Franken. Dies sind jedoch lediglich die Fälle, die dem BACS gemeldet wurden. Es ist davon auszugehen, dass die Dunkelziffer solcher Fälle deutlich höher ist, da Scham, Informationsasymmetrie und mangelndes Bewusstsein zur Dunkelziffer beitragen. Zudem haben Untersuchungen nach den Vorfällen gezeigt, dass in einigen Vorfällen auch andere Mitarbeitende desselben Unternehmens angeschrieben worden sind, die diese Kontaktnahmen jedoch nicht gemeldet haben.

3.2 Informationsasymmetrie

Die zuvor erläuterte Variante des Kryptodiebstahl ist für die Angreifer vorteilhaft, da sie Informationsasymmetrien ausnützt. Einerseits besteht eine solche zwischen den ursprünglichen Zielen, den Mitarbeitenden, und deren Arbeitgebern. Der Grund liegt darin, dass die Mitarbeitenden wenig Anreiz haben, ihren Arbeitgeber über mögliche Sicherheitsverletzungen im Zusammenhang mit der Stellensuche zu informieren, was den Angreifern Zeit verschafft, sich lateral im Unternehmensnetzwerk vorzuarbeiten. Wie zuvor erwähnt, hat das BACS auch Meldungen zu Fällen erhalten, in denen Angreifer mehrere Mitarbeitende desselben Unternehmens kontaktierten, um ihre Erfolgschancen zu maximieren. Denn es ist unwahrscheinlich, dass diese Personen ihre Verdachtsmomente miteinander teilen. Schliesslich möchte niemand gegenüber seinem Arbeitgeber oder seinen Kollegen zugeben, dass er von raffinierten Cyberbedrohungsakteuren getäuscht und vom gefälschten Angebot ernsthaft in Versuchung geführt wurde.

Andererseits besteht eine andere Art der Informationsasymmetrie im Kontext der immensen Ökosystemen aus Open-Source-Software, die von Unternehmen genutzt werden. Für Entwickler ist es nahezu unmöglich, die Sicherheit der unzähligen modularen Open-Source-Bibliotheken, auf die sie sich in ihrer Arbeit stützen, kontinuierlich auf Sicherheitsmängel zu überprüfen. Daher versetzen Angreifer aller Art eine grosse Anzahl von mit «Typosquatting»⁸⁵ versehene Paketen auf Open-Source-Plattformen mit Schadsoftware und setzen darauf, dass mindestens eines davon von den Verteidigern übersehen wird.⁸⁶ Nur gemeinsame Überwachungsbemühungen von Sicherheitsforschern tragen dazu bei, dass diese sich ständig weiterentwickelnde Vielfalt an böartigem Code von den Plattformen entfernt wird, auf die sich Software-Entwickler am meisten verlassen.⁸⁷ Doch die Bezahlung von zahlreichen Forschern oder der Einsatz von KI-Rechenressourcen zur Erkennung der neuesten Malware-Samples ist kostspielig und muss durch andere Cybersicherheitsprodukte querfinanziert werden. Somit ist das Open-Source-Ökosystem ein relativ unüberwachtes Allgemeingut, das Angreifer für ihre eigenen Zwecke missbrauchen können.

Nebst den Open-Source-Ressourcen nutzen die Angreifer legitime Cloud-basierte Dienste, um ihre Schadsoftware zu verteilen. So greifen sie beispielsweise auf online Speicherdienste für JSON-Dateien zurück, die häufig von Software-Entwicklern genutzt werden.⁸⁸ Für einen Cybersicherheitsexperten, der die Protokolle des gesamten Internetverkehrs dieser Websites untersucht, erscheint die Aktivität zunächst wie normales Entwicklerverhalten. Erst wenn weitere Indikatoren einer Kompromittierung (IOCs) damit in Zusammenhang gebracht werden können, wird die böartige Natur des «Dream Job Playbook» und der Malware offensichtlich. Darüber hinaus haben die Unternehmen, die diese Cloud-Dienste betreiben, wenig finanziellen Anreiz,

⁸⁵ [Cybersquatting \(bacs.admin.ch\)](https://bacs.admin.ch)

⁸⁶ Die Manipulation von Open-Source-Paketen ist nicht auf eine bestimmte Kategorie von Bedrohungsakteuren beschränkt. Die dokumentierten Fälle reichen von finanziell motivierten kriminellen Gruppen (z. B. [TeamPCP](#)) bis hin zu staatlich geförderten Bedrohungsakteuren (z. B. [Lazarus Group](#), [APT29](#)).

⁸⁷ Dies kann beispielsweise im npm-Ökosystem geschehen, siehe [«North Korea's Contagious Interview Campaign Escalates: 338 Malicious npm Packages, 50,000 Downloads» \(socket.dev\)](#).

⁸⁸ Die gleiche Methode wurde im Zusammenhang mit der der DVRK zugeschriebenen Aktivität beobachtet, siehe [«Contagious Interview Actors Now Utilize JSON Storage Services for Malware Delivery» \(blog.nviso.eu\)](#).

strengere Know-Your-Customer-Prüfungen (KYC) einzuführen, da dies für sie zu einem Nettoverlust führen kann.

3.3 Kollektive Selbstverteidigung

Kryptodiebstahl, der sich als Traumjob tarnt, ist generell nichts Neues in der Cyberwelt. Bürgerinnen und Bürger, die sich für Cybersicherheit interessieren, lesen schon seit Jahren über diese Art von Angriffen. Und doch reicht das Bewusstsein nicht über die Gemeinschaft der Cyber- und Informationssicherheit in der Schweiz hinaus. Das BACS ist zum Schluss gekommen, dass ein erheblicher Teil der Schweizer Unternehmenswelt aufgrund der beobachteten betrügerischen Kryptoaktivitäten im Zusammenhang mit Traumjobs einem beträchtlichen Risiko ausgesetzt ist. Das Versäumnis, systematische Gegenmassnahmen als Reaktion auf diese Bedrohung zu ergreifen, kann für die Opfer substanzielle Schäden wie z. B. Konkurs bedeuten. Zudem haben die initialen Opfer kaum Anreize, ihre Erfahrung und potenzielle Notlage ihrem Arbeitgeber und oft auch Behörden wie dem BACS zu melden. Ebenso neigen die Anreizstrukturen der Cybersicherheitsbranche dazu, stärker in die ständige Überwachung des Open-Source-Ökosystems zu investieren, während Cloud-basierte Dienstleister unabhängig von den Kundenmotiven ihre Gewinne maximieren wollen. Daher sind die Massnahmen des BACS von Natur aus vorfallsorientiert: Laufende Kampagnen werden analysiert, das Herunternehmen oder Sperren von bössartiger Infrastruktur eingeleitet und Informationen betroffener Organisationen gesammelt, um weitere potenzielle Opfer vor dem Schadensfall zu identifizieren und zu warnen. Dieser Bericht plädiert für einen Paradigmenwechsel von der passiven zur aktiven Selbstverteidigung. Eine Veränderung, die aber nur gelingen kann, wenn die aktuelle Bedrohungslage über die Cybersicherheitsspezialisten hinaus verstanden wird. Je besser auch die breite Öffentlichkeit über das «Dream Job Playbook» und die derzeit ins Visier genommenen Organisationen und Personen informiert ist, desto weniger gefährdet sind potenzielle Ziele, Opfer dieser anhaltenden Cyberbedrohung zu werden. Entscheidend ist auch, dass sich ein generell steigendes Bewusstsein zu einem sich selbstverstärkendem Schutz entwickelt: Je mehr Personen solche betrügerischen Kontaktaufnahmen als das erkennen, was sie sind, desto mehr Informationen können bei einer Meldung gesammelt werden. Indem die Angreifer dazu verleitet werden, ihre Links zu bössartigen Repositorien zu senden, können diese umgehend analysiert und ihre Indikatoren einer Kompromittierung zeitnah zur Warnung an die Bevölkerung verteilt werden. Zusammenfassend ist ein kollektiver und präventiver Ansatz die effektivste Verteidigung, um diesem aktuellen Bedrohungsphänomen zu begegnen.